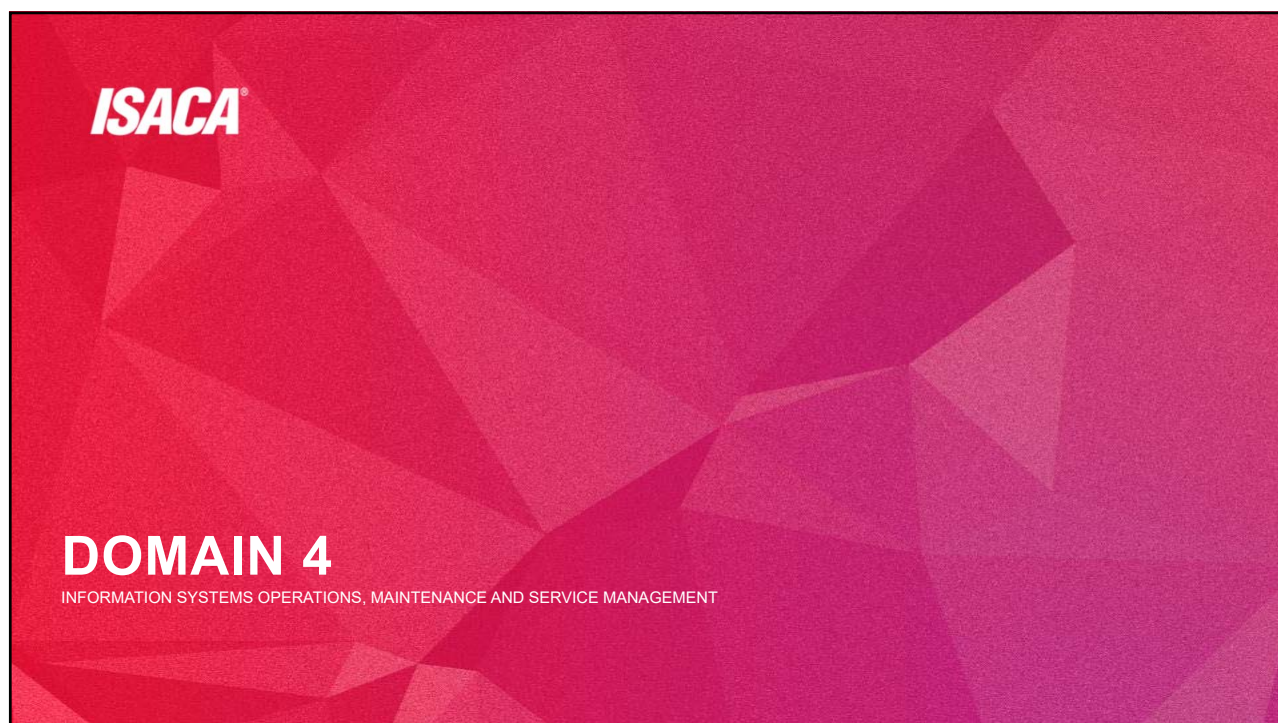
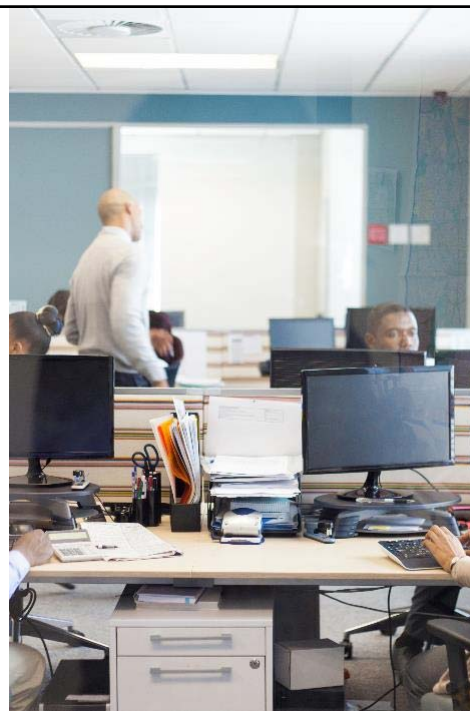




1

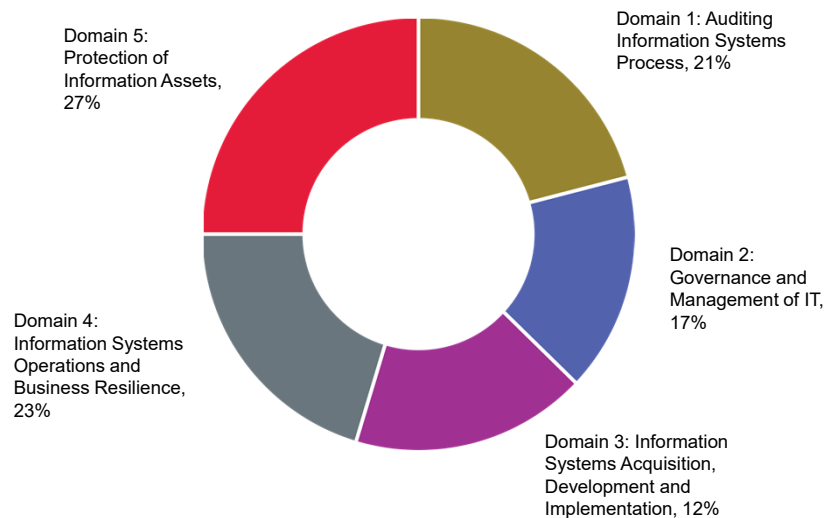
DOMAIN 4

Information systems operations and business resilience are important to provide assurance to users as well as management that the expected level of service will be delivered. Service level expectations are derived from the organization's business objectives. IT service delivery includes IS operations, IT services and management of IS and the groups responsible for supporting them. Disruptions are also an often unavoidable factor of doing business. Preparation is key to being able to continue business operations while protecting people, assets and reputation. Employing business resiliency tactics helps organizations address these issues and limit the impact.



2

ON THE CISA EXAM



ISACA

3

DOMAIN 4 OBJECTIVES

Within this domain an IS auditor should be able to:

- Evaluate the organization's ability to continue business operations.
- Evaluate whether IT service management practices align with business requirements.
- Conduct periodic review of information systems and enterprise architecture.
- Evaluate IT operations to determine whether they are controlled effectively and continue to support the organization's objectives.
- Evaluate IT maintenance practices to determine whether they are controlled effectively and continue to support the organization's objectives.
- Evaluate database management practices.
- Evaluate data governance policies and practices.
- Evaluate problem and incident management policies and practices.
- Evaluate change, configuration, release, and patch management policies and practices.
- Evaluate end-user computing to determine whether the processes are effectively controlled.
- Evaluate policies and practices related to asset lifecycle management.

ISACA

4

DOMAIN 4 TOPICS

Information System Operations:

- Computer Hardware Components and Architectures
- IT Asset Management
- System Interfaces
- End-User Computing
- Data Governance
- Systems Performance Management
- Problem and Incident Management
- Change, Configuration, Release, and Patch Management
- IT Service Level Management
- Database Management

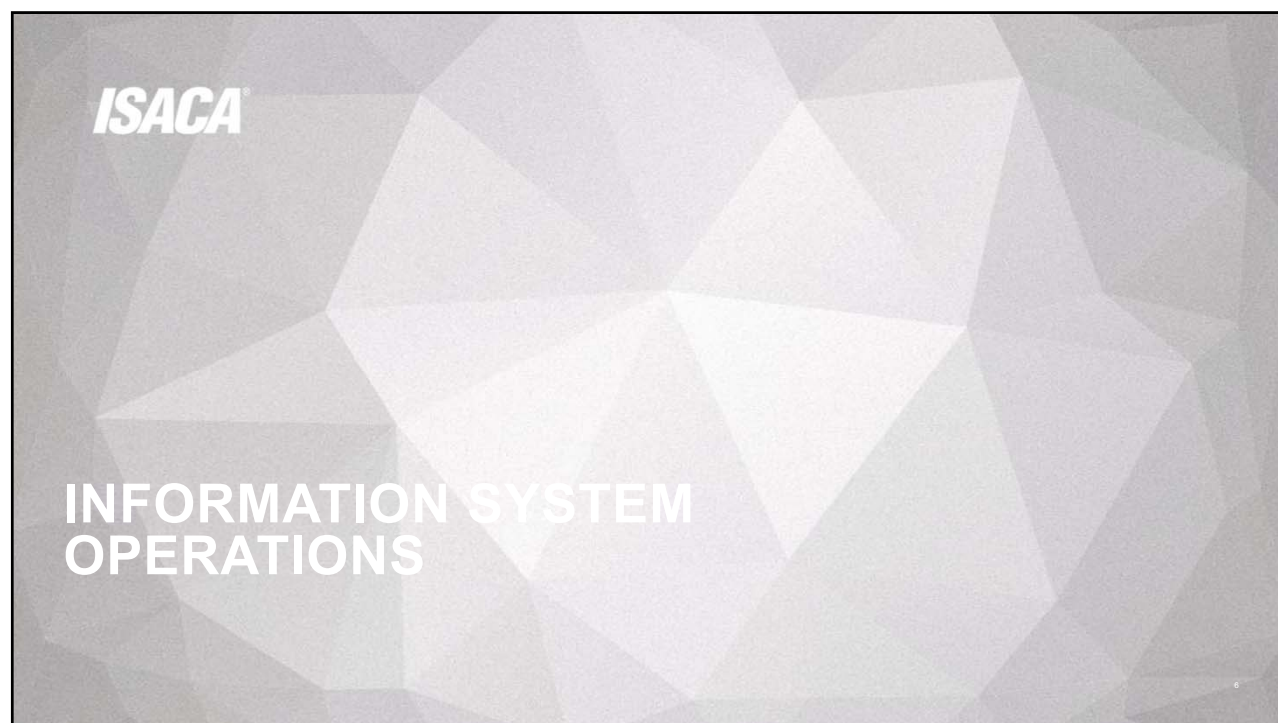
Business Resilience

- Business Impact Analysis (BIA)
- System Resiliency
- Data Backup, Storage, and Restoration
- Business Continuity Plan (BCP)
- Disaster Recovery Plans (DRPs)

5

ISACA

5



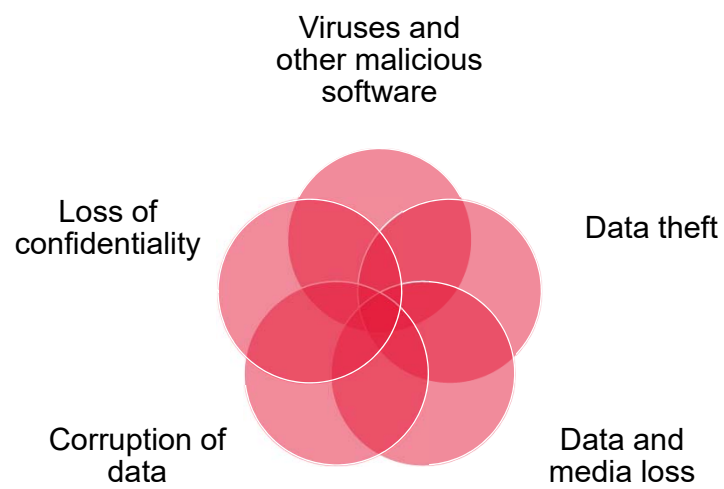
6

COMPUTER HARDWARE COMPONENTS AND ARCHITECTURES

ISACA

7

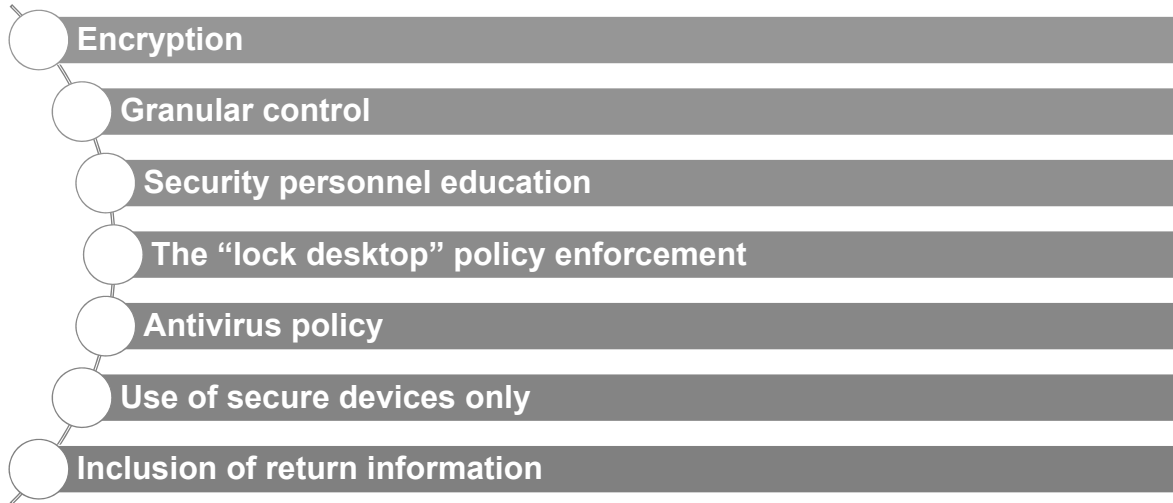
RISKS RELATED TO USBs



ISACA

8

SECURITY CONTROLS RELATED TO USBs

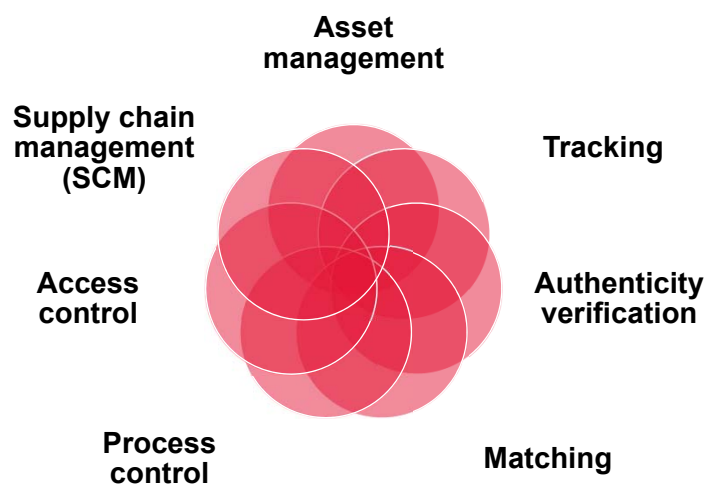


9

ISACA

9

APPLICATION OF RFID



10

ISACA

10

RISK ASSOCIATED WITH RFID



11

ISACA

11

SECURITY CONTROLS FOR RFID

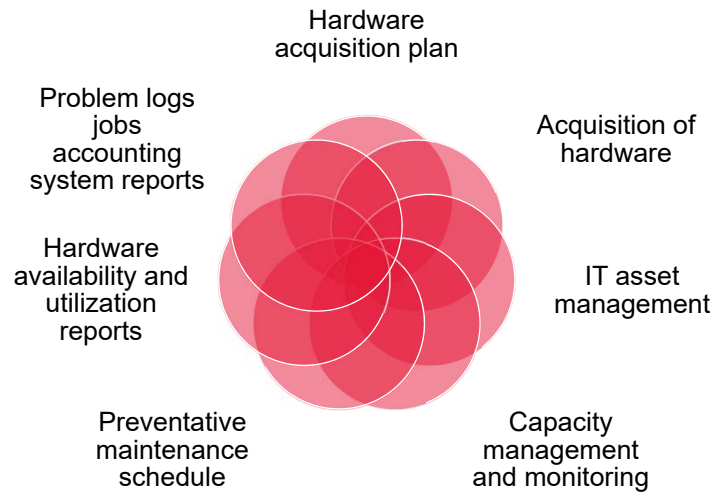
Management
Operational
Technical



12

12

HARDWARE REVIEWS



13

ISACA

13

IT ASSET MANAGEMENT

14

ISACA

14

IT ASSET MANAGEMENT

The inventory record of each information asset should include:

- Owner
- Designated custodian
- Specific identification of the asset
- Relative value to the organization
- Loss implications and recovery priority
- Location
- Security/risk classification
- Asset group (where the asset forms part of a larger information system)

15

The first step in IT asset management is the process of identifying and creating an inventory of IT assets for both software and hardware.

ISACA

15

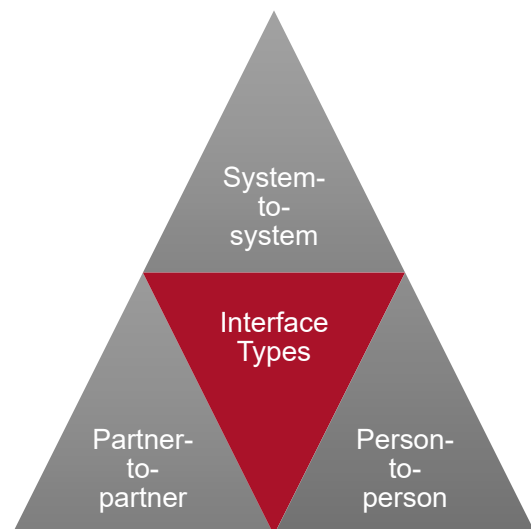
SYSTEM INTERFACES

16

ISACA

16

SYSTEM INTERFACES



System interfaces exist where data output from one application is sent as input to another with little or no human interaction.

ISACA

17

17

RISK ASSOCIATED WITH SYSTEM INTERFACES

Integrity of data exchange
Data security
Privacy
Legal



18

18

SECURITY ISSUES IN SYSTEM INTERFACES

Secure data transfers ensures data integrity

Secure data transfers ensure confidentiality and protected from:

- unauthorized access to the data via interception
- malicious activity
- error or other means

Availability of system interfaces impact data reliability

19

ISACA

19

CONTROLS ASSOCIATED WITH SYSTEM INTERFACES

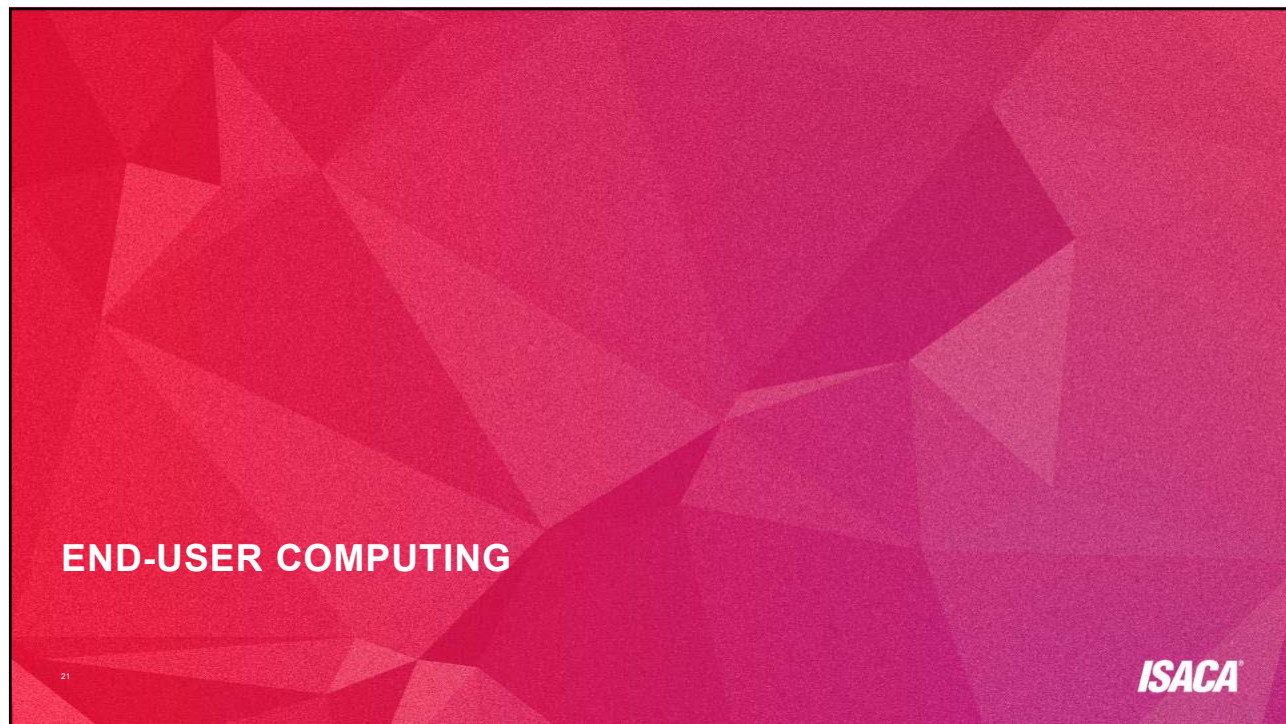
IS auditors should ensure the program is able to:

- Manage multiple file transfer mechanisms.
- Use multiple protocols.
- Automatically encrypt, decrypt and electronically sign data files.
- Compress/decompress data files.
- Connect to common database servers.
- Send and retrieve files via email and secure email.
- Automatically schedule regular data transfers.
- Analyze, track and report any attributes of the data being transferred.
- Ensure compliance with appropriate regulatory laws and mandates.
- Offer a checkpoint or restart capability for interruptions.
- Integrate with back-office applications to automate data transfers as much as feasible.

20

ISACA

20



21

END-USER COMPUTING BENEFITS & RISKS

Benefits

- Quick deployment of applications
- Enables organizations to be more agile
- Removes some pressure from IT

Risks

- May not be subject to independent review
- May not have formal department structure

Results in:

- May contain errors and give incorrect results
- Are not subject to change management or release management, resulting in multiple, perhaps different, copies
- Are not secured
- Are not backed up

22

ISACA

22

END-USER COMPUTER SECURITY RISKS

Authorization

- There may be no secure mechanism to authorize access to the system.

Authentication

- There may be no secure mechanism to authenticate users to the system.

Audit logging

- This is not available on standard EUC solutions (e.g., Microsoft Excel and Access).

Encryption

- The application may contain sensitive data which have not been encrypted or otherwise protected.

23

ISACA

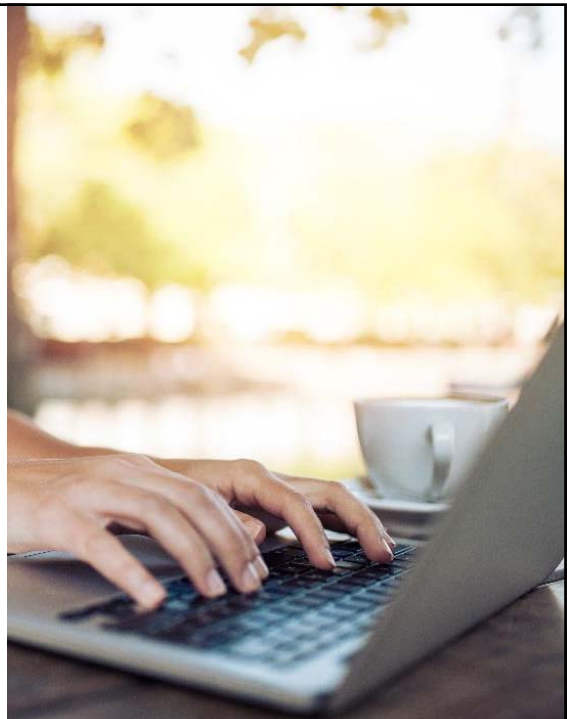
23



ACTIVITY

Your audit of the software development activities has identified that several end-user computing solutions interface with the ERP. These end-user computing applications are normally being saved to local hard drives and frequently are used for extended periods off-line from corporate networks.

What policy for use of end-user computing should the IS auditor ensure is in place?

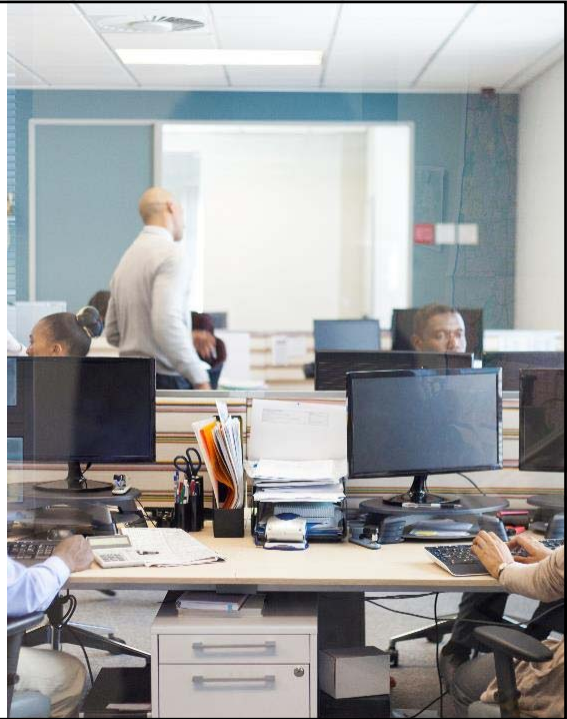


24

DISCUSSION QUESTION

An IS auditor discovers that some users have installed personal software on their PCs. This is not explicitly forbidden by the security policy. Of the following, the **BEST** approach for an IS auditor is to recommend that the:

- A. IT department implement control mechanisms to prevent unauthorized software installation.
- B. security policy be updated to include specific language regarding unauthorized software.
- C. IT department prohibit the download of unauthorized software.
- D. users obtain approval from an IS manager before installing nonstandard software.

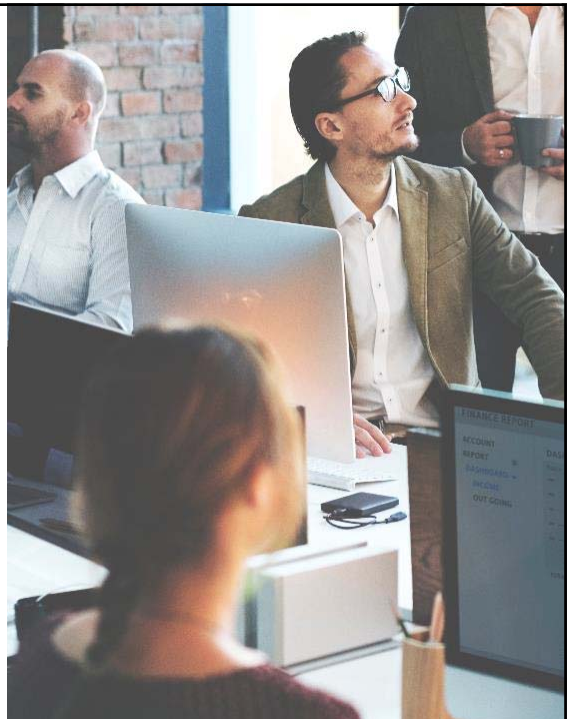


25

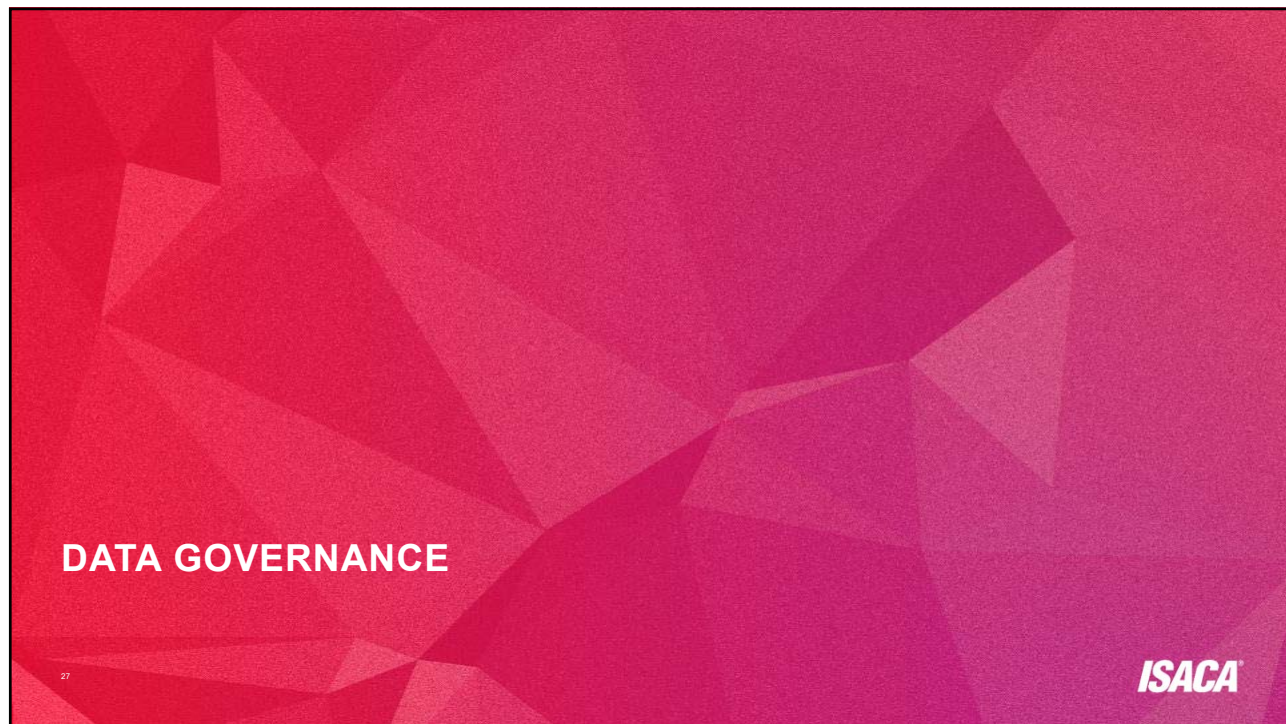
DISCUSSION QUESTION

Which of the following is a prevalent risk in the development of end-user computing (EUC) applications?

- A. Applications may not be subject to testing and IT general controls.
- B. Development and maintenance costs may be increased.
- C. Application development time may be increased.
- D. Decision-making may be impaired due to diminished responsiveness to requests for information.



26

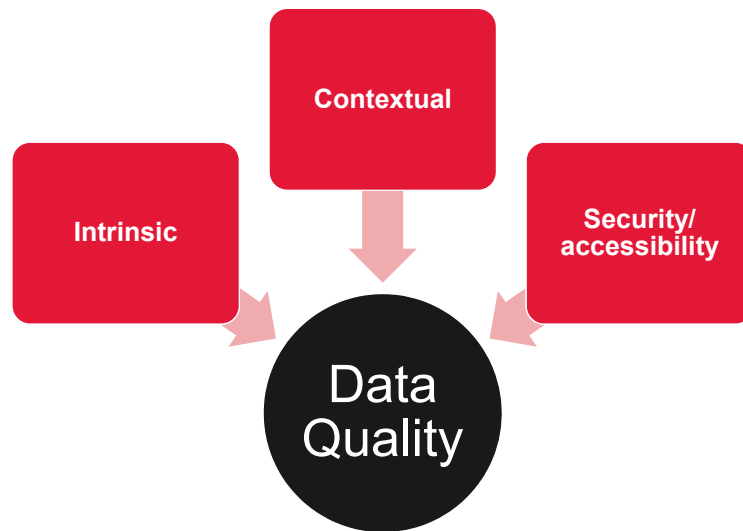


27

DATA GOVERNANCE Stakeholder needs, conditions and options are evaluated to determine balanced, mutually agreed enterprise objectives to be achieved through the acquisition and management of data/information resources. Direction is set for data/information management capabilities through prioritization and decision making. Performance and compliance of data/information resources are monitored and evaluated relative to mutually agreed-upon (by all stakeholders) direction and objectives.	Ensures - Confidentiality - Integrity - Availability of data ISACA
---	--

28

DATA QUALITY

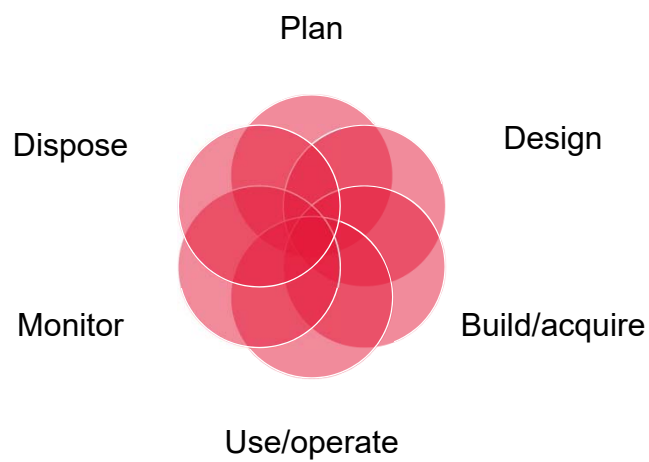


29

ISACA

29

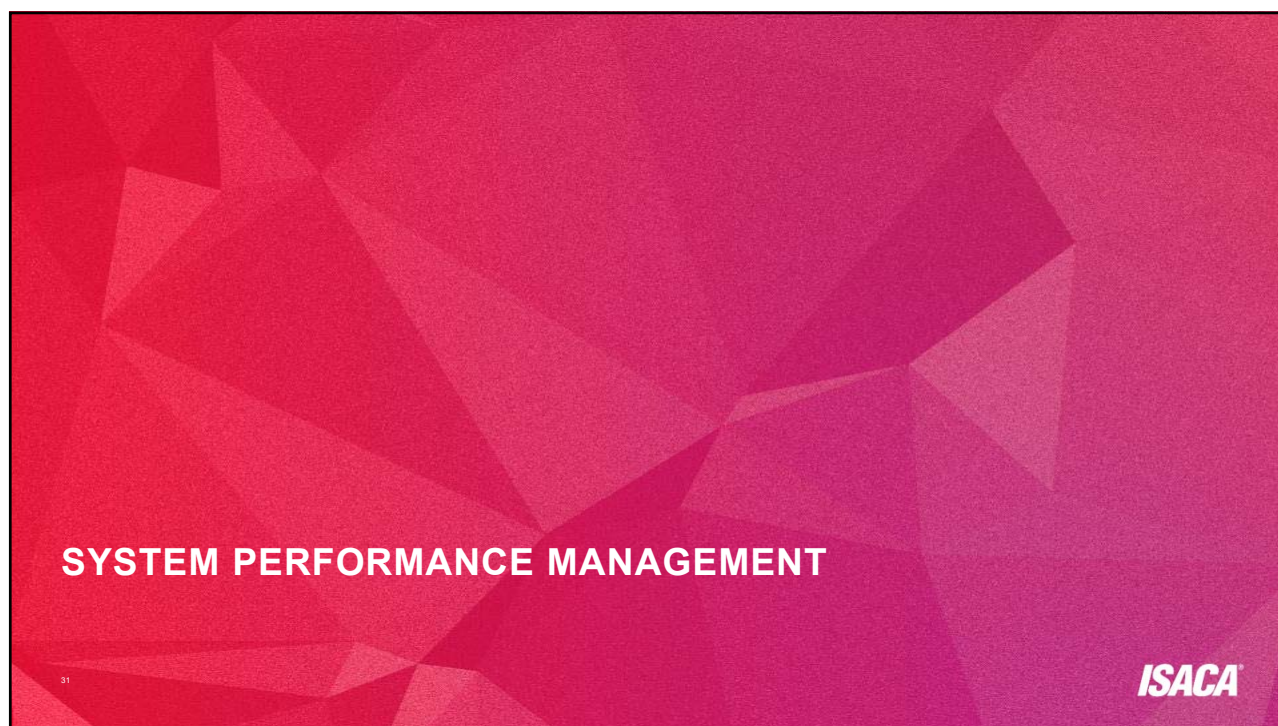
DATA MANAGEMENT



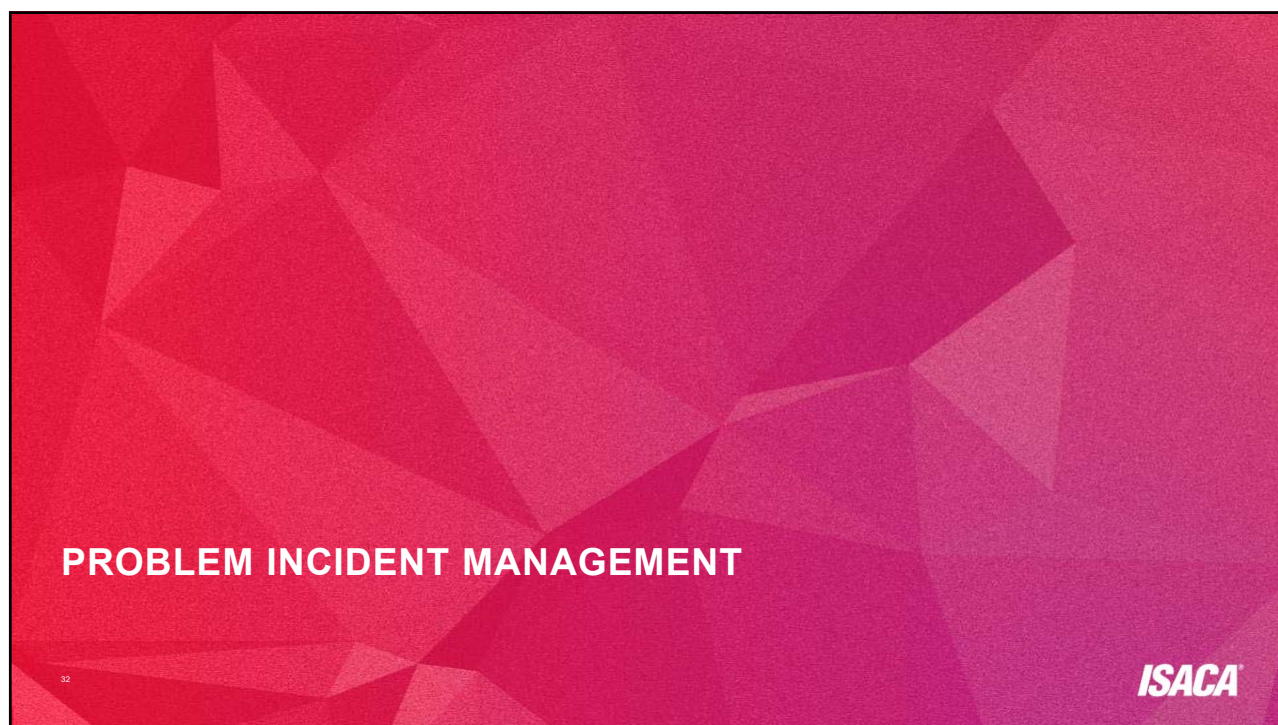
30

ISACA

30



31



32

PROBLEM MANAGEMENT

Problem management's objective is to reduce the number and/or severity of incidents.

Effective problem management can show a significant improvement in the quality of service of an IS organization.



33

33

PROCESS OF INCIDENT HANDLING

Incident management focuses on providing increased continuity of service by reducing or removing the adverse effect of disturbances to IT services and covers almost all nonstandard operations of IT services—thereby defining the scope to include virtually any nonstandard event.

Incident management is reactive and its objective is to respond to and resolve issues restoring normal service (as defined by the SLA) as quickly as possible.

It is essential for any incident handling process to prioritize items after determining the impact and urgency.

34

ISACA

34

DETECTION, DOCUMENTATION, CONTROL, RESOLUTION AND REPORTING OF ABNORMAL CONDITIONS

Automated control logs – document any abnormal conditions. For control purposes, the ability to add to the error log should not be restricted.

The ability to update the error log should be restricted to authorized individuals, and the updates should be traceable.

IS management should:

- Maintain and monitor logs
- Develop operations documentation for escalation

IS auditor should examine reports and logs to ensure prompt resolution and proper assignment

35

ISACA

35

SUPPORT/HELP DESK

Procedures covering the tasks to be performed by the technical support personnel must be established in accordance with an organization's overall strategies and policies.



36

36

NETWORK MANAGEMENT TOOLS

Response time reports
 Downtime reports
 Help desk reports
 Online monitors
 Network monitors
 Network (protocol) analyzers
 Simple Network Management Protocol (SNMP)



37

37

PROBLEM REPORTING REVIEW

Interviews with IS personnel

- Have documented procedures been developed to guide the logging, analysis, resolution and escalation of problems?
- Are these actions performed in a timely manner, in accordance with management's intent and authorization?

Procedures and documentation

- Are procedures adequate for recording, evaluating, resolving or escalating problems?
- Is IT statistics collection and analysis adequate, accurate and complete?
- Are all identified problems recorded for verification and resolution?

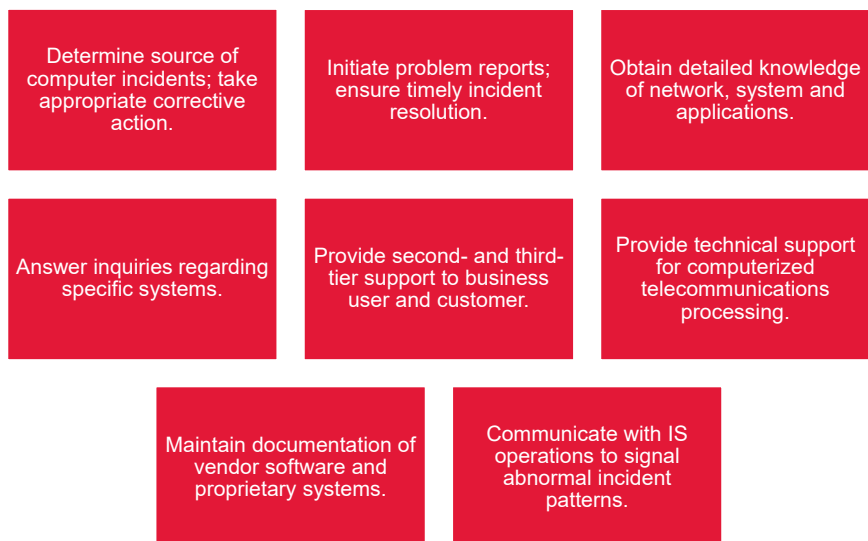
Logs and records

- Are the reasons for delays in application program processing valid?
- Are significant and recurring problems identified and actions taken to prevent their recurrence?
- Are there any recurring problems that are not being reported to IS management?

ISACA

38

THE SUPPORT FUNCTION



ISACA

39



ACTIVITY

During the review of company audit logs, the IS auditor identified the following findings:

- Excel database ODBC functionality was being used to back-door the MS SQL databases.
- On-going Metasploit attacks that were targeting external firewalls have not been escalated for response.

What is the best way to address database and firewall attacks?



40

DISCUSSION QUESTION

Which of the following specifically addresses how to detect cyberattacks against an organization's IT systems and how to recover from an attack?

- A. An incident response plan (IRP)
- B. An IT contingency plan
- C. A business continuity plan (BCP)
- D. A continuity of operations plan (COOP)

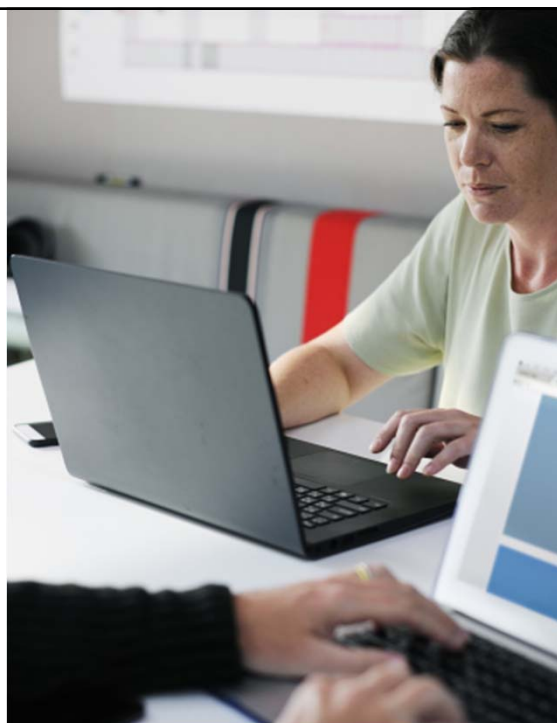


41

DISCUSSION QUESTION

The PRIMARY objective of performing a postincident review is that it presents an opportunity to:

- A. improve internal control procedures.
- B. harden the network to industry good practices.
- C. highlight the importance of incident response management to management.
- D. improve employee awareness of the incident response process.



42

CHANGE, CONFIGURATION, RELEASE, AND PATCH MANAGEMENT

ISACA

43

CHANGE MANAGEMENT

The change management process is implemented when:

- Hardware is changed.
- Software is installed or upgraded.
- Network devices are configured.

Change control is part of the broader change management process.

It is designed to control the movement of application changes from the test environment through QA and into the production environment.

ISACA

44

CHANGE MANAGEMENT (CONT'D)

The change management process ensures that:

- Relevant personnel are aware of the change and its timing.
- Documentation is complete and in compliance.
- Job preparation, scheduling and operating instructions have been established.
- System and program results have been reviewed and approved by both project management and the end user.
- Data file and system conversions have been completed accurately and completely.
- All aspects of jobs turned over have been tested, reviewed and approved by control/operations personnel.
- Legal and compliance issues have been addressed.
- Risk associated with the change has been planned for, and a rollback plan has been developed to back out the changes should that become necessary.

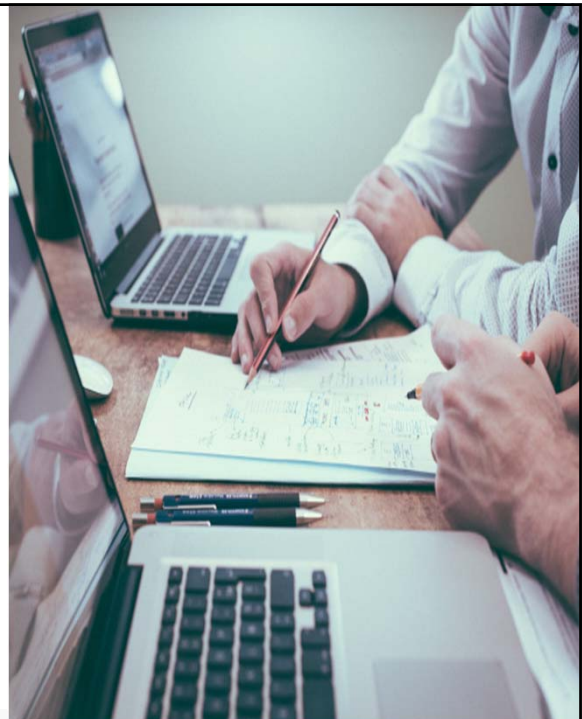
ISACA

45

CHANGE REQUESTS

Formalized and documented change processes incorporate the following elements:

- Change request
- Authorization
- Testing
- Implementation
- Communication to end users



46

CHANGE REQUESTS (CONT'D)

Procedures associated with these may vary according to the type of change request, including:

- Emergency changes
- Major changes
- Minor changes

ISACA

47

ACTIVITY

The ERP upgrades went very well; however, the subsequent bug fix and software patching has caused on-going system outages and data corruption. You have been asked to perform a management request audit to determine the root causes of the failures.

As you begin the audit, where would be the best place to focus your attention?

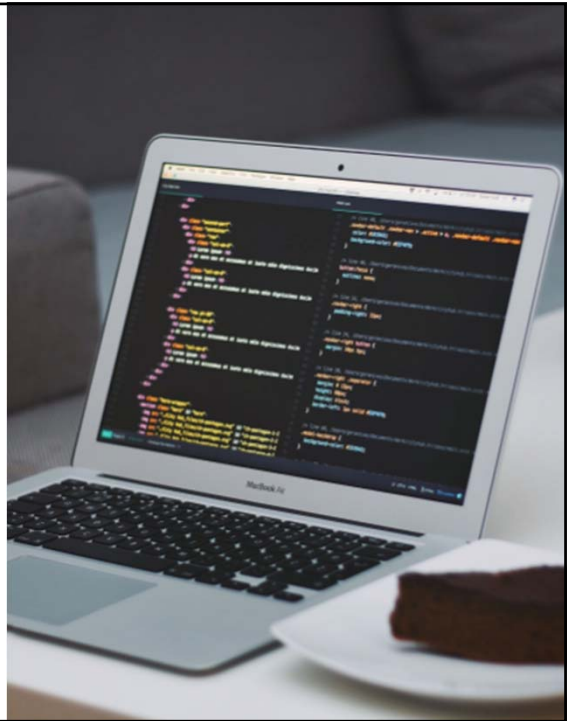


48

DISCUSSION QUESTION

In a small organization, developers may release emergency changes directly to production. Which of the following will **BEST** control the risk in this situation?

- A. Approve and document the change the next business day.
- B. Limit developer access to production to a specific time frame.
- C. Obtain secondary approval before releasing to production.
- D. Disable the compiler option in the production machine.



49

DISCUSSION QUESTION

During an audit of a small enterprise, the IS auditor noted that the IS director has superuser-privilege access that allows the director to process requests for changes to the application access roles (access types). Which of the following should the IS auditor recommend?

- A. Implement a properly documented process for application role change requests.
- B. Hire additional staff to provide a segregation of duties (SoD) for application role changes.
- C. Implement an automated process for changing application roles.
- D. Document the current procedure in detail, and make it available on the enterprise intranet.



50

HARDWARE MAINTENANCE

To perform optimally, hardware must be cleaned and serviced on a routine basis.

When performing an audit of this area, the IS auditor should:

- Ensure that a formal maintenance plan has been developed. This must be:
 - Approved by management
 - Implemented and followed
- Identify maintenance costs that exceed budget or are excessive.



51

CAPACITY MANAGEMENT

Computing and network resources must be planned and monitored to ensure that they are used efficiently and effectively.

A capacity plan should be developed based on input from both users and IS managers, and should be reviewed and updated at least annually.

The IS audit should take into account that capacity requirements may:

- Fluctuate according to business cycles
- Be interdependent across the capacity plan



52

RELEASE MANAGEMENT

Major release

- Normally contains a significant change or addition to a new functionality
- These usually supersede all preceding minor upgrades

Minor release

- Upgrades, offering small enhancements and fixes
- Usually supersedes all preceding emergency fixes

Emergency release

- Normally contains corrections to a small number of known problems
- These require implementation as quickly as possible, limiting the execution of testing and release management activities

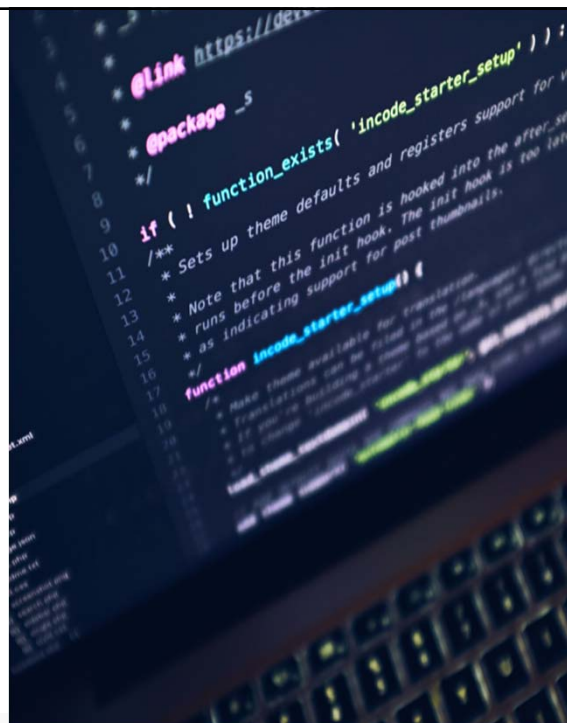
ISACA

53

PATCH MANAGEMENT

A patch is software code that is installed to maintain software as current between full-scale version releases.

A patch often addresses security risks that have been detected in the original code.



54

PATCH MANAGEMENT (CONT'D)

Patch management tasks include:

- Maintaining current knowledge of available patches
- Determining which patches are appropriate for particular systems
- Ensuring that patches are properly installed
- Testing systems after installation
- Documenting all patch-related procedures

Because a patch can introduce new problems to a system, it is a good practice to test a patch on a non-critical system and perform backups prior to installing patches.

ISACA

55

QUALITY ASSURANCE (QA)

Prior to the introduction of system changes to the production environment, a QA process should be in place to verify that these changes are:

- Authorized
- Tested
- Implemented in a controlled manner

QA personnel also oversee the proper maintenance of program versions and source code to object.

ISACA

56

CONTRACTUAL PROVISIONS

The use of third-party recovery alternatives should be guided by contractual provisions such as the following:

- Hardware and software configurations
- Disaster magnitude definition
- Private versus shared facility use
- Organization's priority relative to other users
- Immediacy and duration of availability
- Security and audit considerations

ISACA

57



ACTIVITY

During your IS audit you have found that critical patches are not being applied due to recent outages experienced from the automated patching processes.

What is the most important aspect of patching that leads to system outages?



58

DISCUSSION QUESTION

During fieldwork, an IS auditor experienced a system crash caused by a security patch installation. To provide reasonable assurance that this event will not recur, the IS auditor should ensure that:

- A. only systems administrators perform the patch process.
- B. the client's change management process is adequate.
- C. patches are validated using parallel testing in production.
- D. an approval process of the patch, including a risk assessment, is developed.

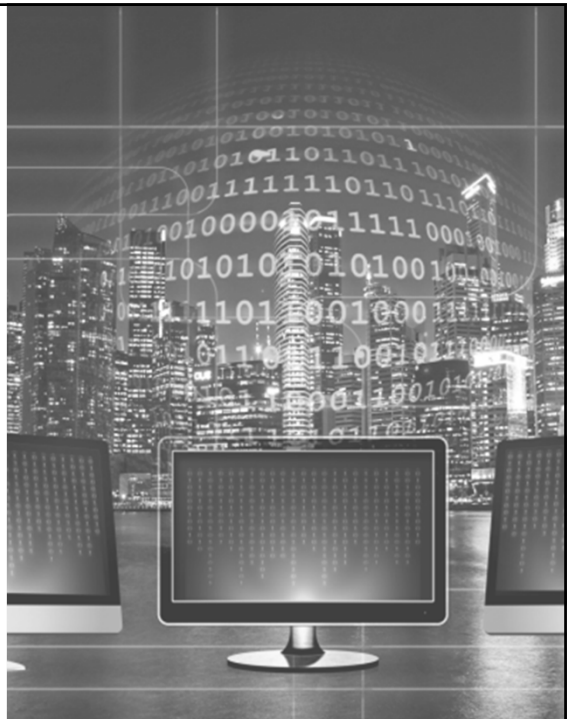


59

DISCUSSION QUESTION

Which of the following ways is the **BEST** for an IS auditor to verify that critical production servers are running the latest security updates released by the vendor?

- A. Ensure that automatic updates are enabled on critical production servers.
- B. Verify manually that the patches are applied on a sample of production servers.
- C. Review the change management log for critical production servers.
- D. Run an automated tool to verify the security patches on production servers.



60

IS OPERATIONS

The IS operations function is responsible for the ongoing support of an organization's computer and IS environment, ensuring:

- Computer processing requirements are met
- End users are satisfied
- Information is processed securely
- Outside parties (third parties, cloud computing) meet the company's processing requirements

ISACA

61

IS OPERATIONS (CONT'D)

The organization of IS operations varies depending on the size of the computing environment.

The IS auditor should understand the scope of IS operations when conducting an audit of this area.



62

IS OPERATIONS DOCUMENTATION

The IS control environment requires procedures detailing operational tasks and processes as well as IS management oversight.

The ISACA logo, consisting of the word "ISACA" in a bold, sans-serif font.

63

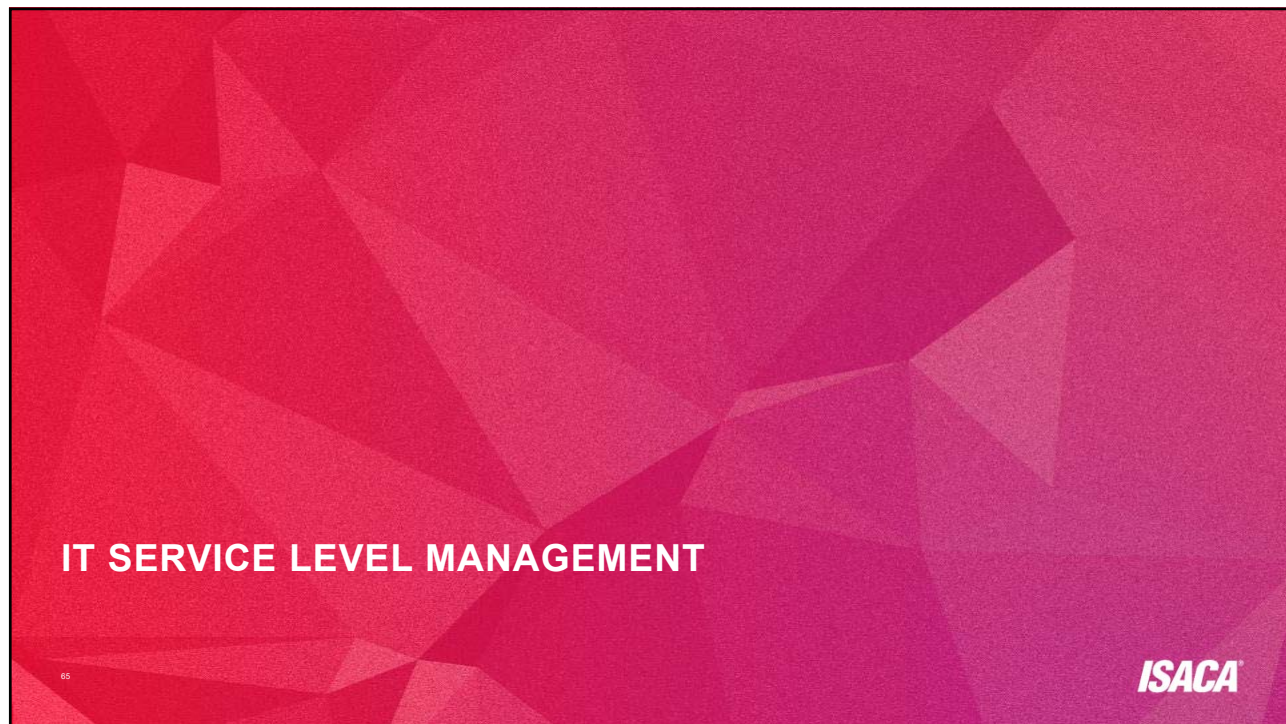
IS OPERATIONS DOCUMENTATION (CONT'D)

Such documentation includes procedures for:

- Operating instructions and job flows for computers and peripheral equipment
- Monitoring systems and applications
- Detection of system and application errors and issues
- Handling of IS problems and the escalation of unresolved issues
- Backup and recovery

The ISACA logo, consisting of the word "ISACA" in a bold, sans-serif font.

64



65

IT SERVICE MANAGEMENT

IT service management (ITSM) supports business needs through the implementation and management of IT services.

People, processes, and information technology are each a part of IT services.

A service management framework provides support for the implementation of ITSM.

The ISACA logo, consisting of the word "ISACA" in a bold, sans-serif font.

66

ITSM FRAMEWORKS

Two primary frameworks guide ITSM:

- The IT Infrastructure Library (ITIL)
 - The ITIL is a reference for service delivery good practice. These should be adapted to the needs of the specific organization.
- ISO 20000-1:2011 Information technology – Service management – Part 1: Service management system requirements
 - ISO 20000 is primarily used as a demonstration of compliance to accepted good practice. It requires service providers to implement the plan-do-check-act (PDCA) methodology (Deming's quality circle) and apply it to their service management processes.

ISACA

67

THE ITSM PREMISE

The bases of ITSM are:

- IT can be managed through a series of discrete processes.
- These processes provide “service” to the business and are interdependent.

Service level agreements (SLA) detail service expectations.

To ensure high levels of service, ITSM metrics are compared against the SLA expectations.



68

SLA TOOLS

Several reporting tools aid in determining whether service expectations are being met. These include:

- Exception reports
- System and application logs
- Operator problem reports
- Operator work schedules



69

SLA TOOLS (CONT'D)

When there is a contractual relationship between the IT department and the end user or customer, SLA service level definition is particularly important.

- The IS auditor should be aware of these defined expectations, ensuring that they are comprehensive.
- These should include measures to address:
 - Risk, security and control
 - Efficiency and effectiveness

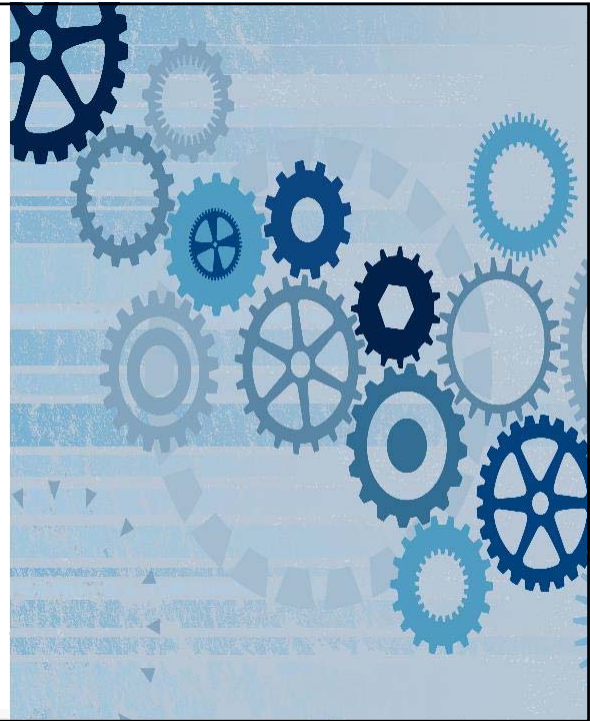


70

AUDIT OF INFRASTRUCTURE

Enterprise architecture (EA) describes the design of the components of a business system or subsystem.

- EA documents an organization's IT assets in a structured form, facilitating consideration of IT investments and clarifying interrelationships between IT components.



71

AUDIT OF INFRASTRUCTURE (CONT'D)

When auditing infrastructure and operations, the IS auditor should:

- Follow the overall EA.
- Use the EA as a main source of information.
- Ensure that IT systems are aligned with the EA and meet organizational objectives.

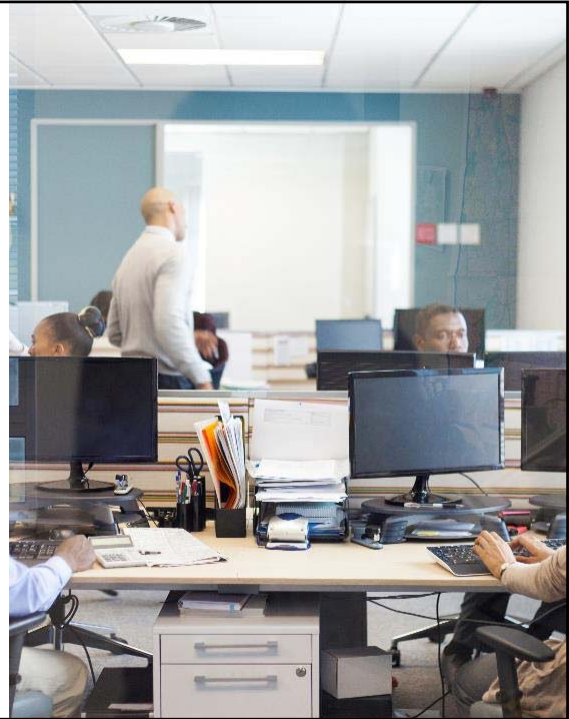
ISACA

72

ACTIVITY

The audit committee has directed the internal audit team to determine if IT services are being managed to optimize value to the company. Your company is considering integration of IT service management (ITSM) for the management of IT services (people, process and information technology) to meet business needs.

What features of ITSM could benefit the organization?

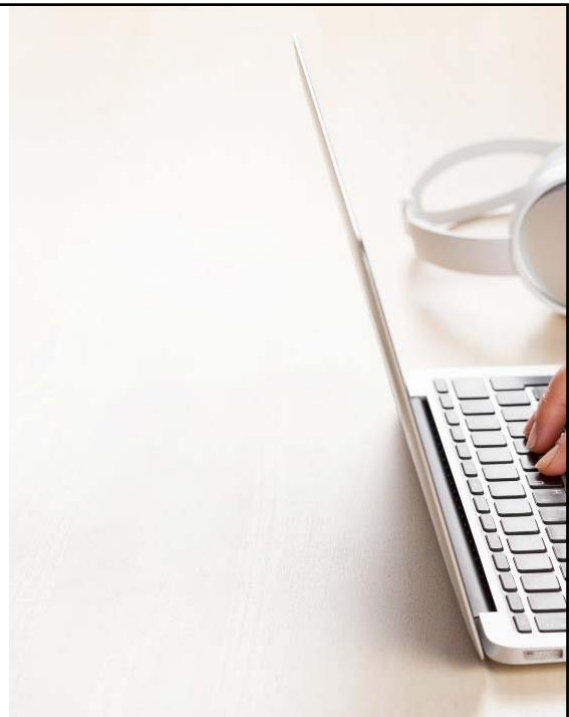


73

DISCUSSION QUESTION

Which of the following issues should be a **MAJOR** concern to an IS auditor who is reviewing a service level agreement (SLA)?

- A. A service adjustment resulting from an exception report took a day to implement.
- B. The complexity of application logs used for service monitoring made the review difficult.
- C. Performance measures were not included in the SLA.
- D. The document is updated on an annual basis.



74

DISCUSSION QUESTION

During a human resources (HR) audit, an IS auditor is informed that there is a verbal agreement between the IT and HR departments as to the level of IT services expected. In this situation, what should the IS auditor do **FIRST**?

- A. Postpone the audit until the agreement is documented.
- B. Report the existence of the undocumented agreement to senior management.
- C. Confirm the content of the agreement with both departments.
- D. Draft a service level agreement (SLA) for the two departments.



75

DATABASE MANAGEMENT

The ISACA logo, consisting of the word "ISACA" in a bold, white, sans-serif font, positioned in the bottom right corner of the slide.

76

DATABASE MANAGEMENT SYSTEM

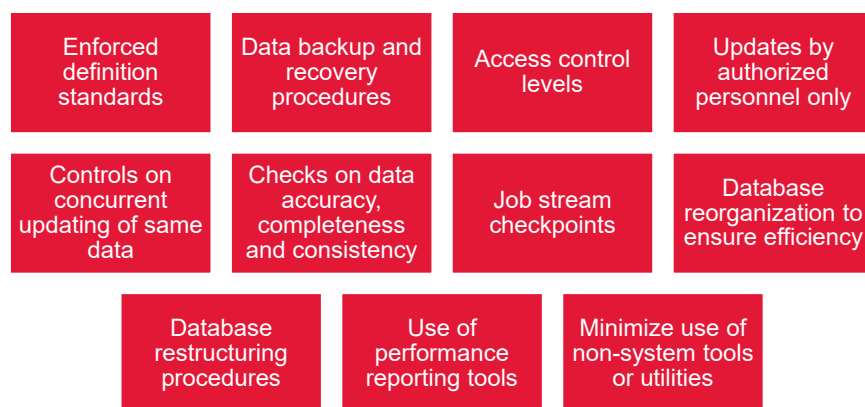
Database management system (DBMS) software offers several benefits:

- Aids in organizing, controlling and using the data needed by application programs
- Provides the facility to create and maintain a well-organized database
- Reduces data redundancy and access time, while offering basic security over sensitive data

ISACA

77

DATABASE CONTROLS



ISACA

78

ACTIVITY

While performing an IS audit of the ERP database and related data warehouse, you have identified the following findings:

- Duplication of data between data sets in the database and the warehouse.
- Insecure data transfers (FTP) were used in many instances.

What would **BEST** address the data duplication issues?

What is the most likely cause of the use of insecure data transfer?



79

DISCUSSION QUESTION

The database administrator (DBA) suggests that database efficiency can be improved by denormalizing some tables. This would result in:

- loss of confidentiality.
- increased redundancy.
- unauthorized accesses.
- application malfunctions.



80

 DISCUSSION QUESTION

Segmenting a highly sensitive database results in:

- A. reduced exposure.
- B. reduced threat.
- C. less criticality.
- D. less sensitivity.



81



82



83

BUSINESS IMPACT ANALYSIS

BIA is a process used to determine the impact of losing the support of any resource.

It is an important adjunct to the risk analysis, often uncovering vital but less visible components that support critical processes.

Three primary questions must be considered during a BIA process:

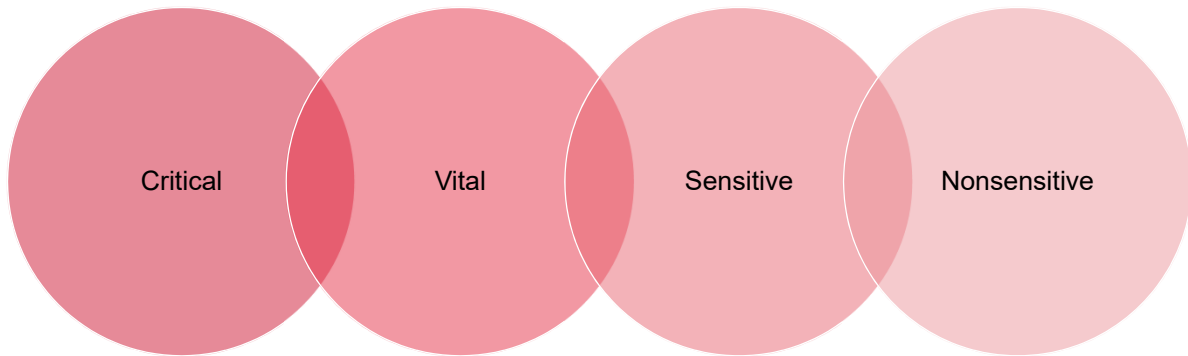
- What are the different business processes?
- What are the critical information resources related to an organization's critical business processes?
- In the event of an impact on critical business processes, under what time frame will significant or unacceptable losses be sustained?

The IS auditor should be able to evaluate the BIA, requiring a knowledge of BIA development methods.

ISACA

84

CLASSIFICATION OF OPERATIONS AND CRITICALITY ANALYSIS



85

ISACA

85

SYSTEM RESILIENCY

86

ISACA

86

APPLICATION RESILIENCY AND DISASTER RECOVERY METHODS

Clustering

- A cluster is a type of software (agent) that is installed on every server (node) in which the application runs and includes management software that permits control of and tuning the cluster behavior.
- Clustering protects against single points of failure (a resource whose loss would result in the loss of service or production). The main purpose of clustering is higher availability.

Active-passive

- The application runs on only one (active) node, while other (passive) nodes are used only if the application fails on the active node.

Active-active

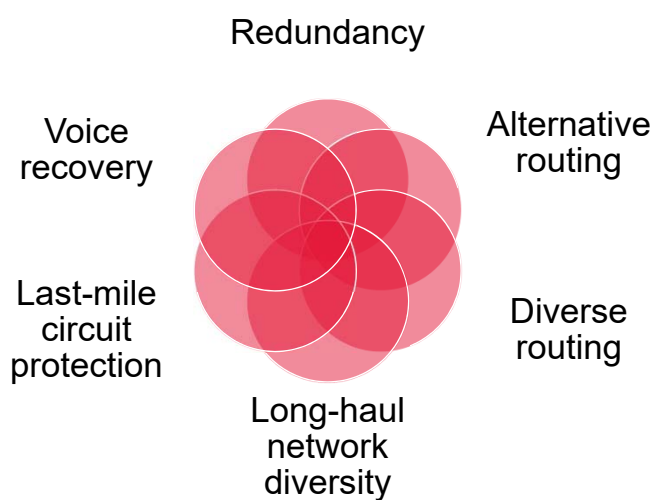
- Clusters require that the application be built to utilize the cluster capabilities.

87

ISACA

87

TELECOMMUNICATION NETWORKS RESILIENCY AND DISASTER RECOVERY METHODS



88

ISACA

88

DATA BACKUP, STORAGE, AND RESTORATION

ISACA

89

BACKUP SCHEMES

Features	Full Backup	Incremental Backup	Differential Backup
What it does?	Copies all main files and folders to the backup media	Copies files and folders that have changed or are new since last backup	Copies files and folders that have been added or changed since a full backup was performed
What are its advantages?	Creates a unique archive in case of restoration	Requires less time and media than full backup	Faster than full backup; requires only latest full and differential backup sets for full restoration
What are its disadvantages?	Requires more time and media capacity than other methods	All backup sets are required to implement a full restoration, taking more time	Requires more time and media capacity than incremental backup

ISACA

90

OFFSITE LIBRARY CONTROLS

Secure physical access to library contents, accessible only to authorized persons

Encryption of backup media, especially during transit

Ensuring that the physical construction can withstand heat, fire and water

Location of the library away from the data center and disasters that may strike both together

Maintenance of an inventory of all storage media and files for specified retention periods

Maintenance of library records for specified retention periods

Maintenance and protection of a catalog of information regarding data files

ISACA

91

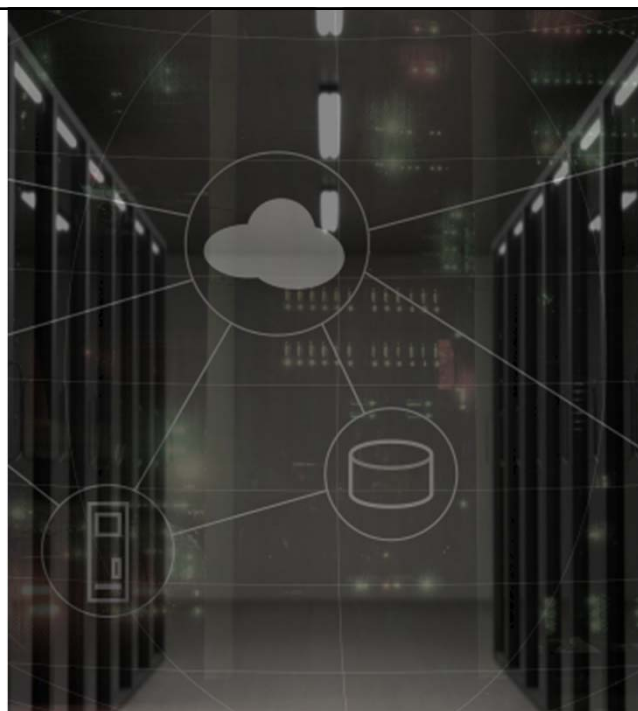
SECURITY AND CONTROL OF OFFSITE FACILITIES

The offsite IPF must be as secured and controlled as the originating site.

The offsite facility should not be easily identified from the outside.

The offsite facility should not be subject to the same disaster event that affected the originating site.

Proper environmental monitoring and controls should be in place



92

92

MEDIA AND DOCUMENTATION BACKUP AND DEVICE TYPES

Duplication of important data and documentation is important for proper recovery.

Device type factors:

- Standardization
- Capacity
- Speed
- Price

Backup types:

- Virtual tape libraries
- Host-based replication
- Disk-array based replication
- Snapshots

93



93

BACKUP SCHEMES

Full backup

Incremental backup

Differential backup

Method of rotation

94



94

ACTIVITY

Recent failures in application and database backups have led to loss of business continuity system fail-over during system outages. During your audit, you have identified that changes were made to systems supporting the backup processes.

Further investigations of the backup issues disclose that backup job scheduling conflicted with other running operations. What would be the **BEST** choice of controls to address this deficiency?



95

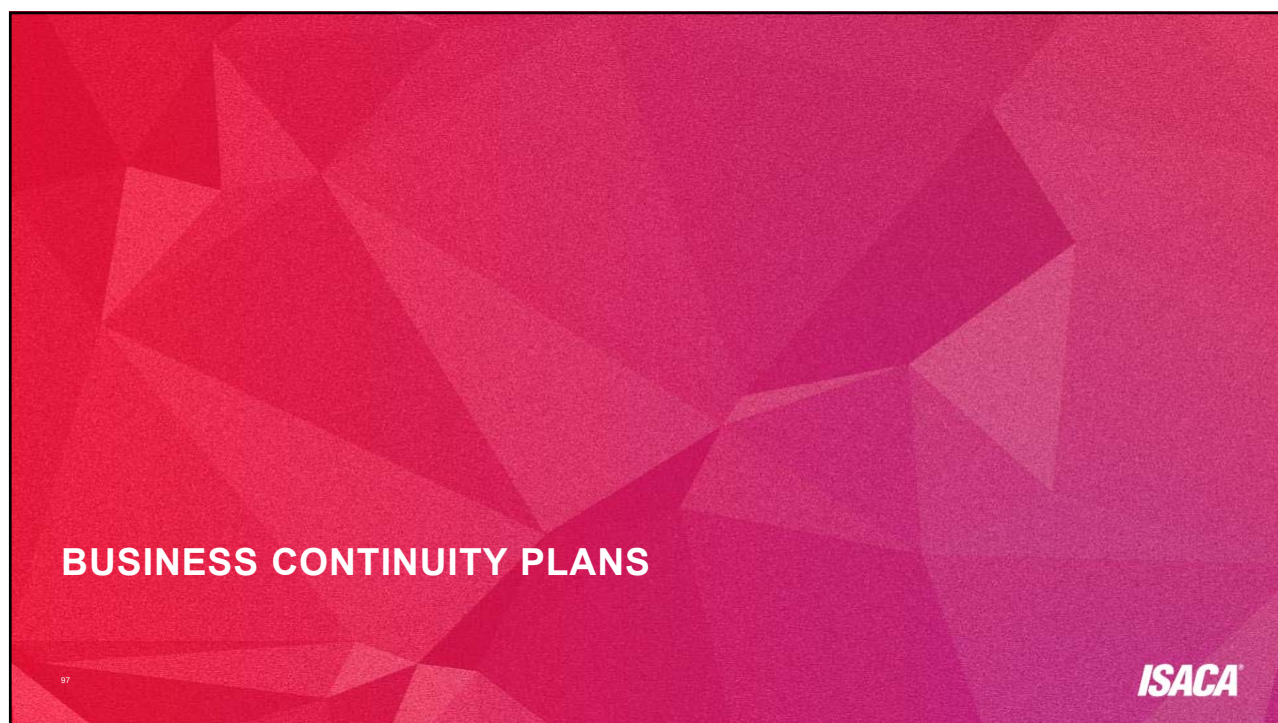
DISCUSSION QUESTION

Which of the following processes should an IS auditor recommend to assist in the recording of baselines for software releases?

- A. Change management
- B. Backup and recovery
- C. Incident management
- D. Configuration management



96



97

BUSINESS CONTINUITY PLANNING

In the event of a disruption of normal business operations, BCP and DRP can allow critical processes to carry on.

Responsibility for the BCP rests with senior management, but its execution usually lies with business and supporting units.

The plan should address all functions and assets that will be required to continue as a viable operation immediately after encountering an interruption and while recovery is taking place.

The ISACA logo is located in the bottom right corner of the slide.

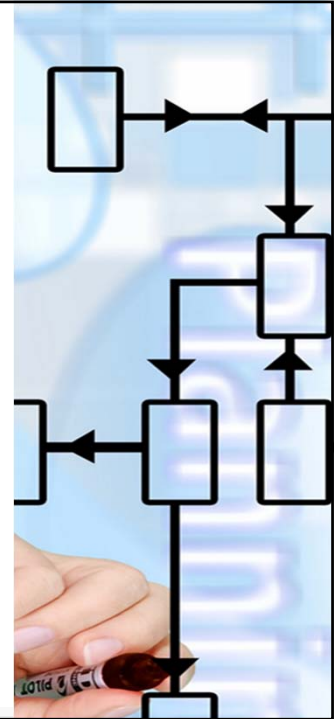
98

DISASTER MANAGEMENT

An IT DRP is a structured collection of processes and procedures designed to speed response and ensure business continuity in the event of a disaster.

Various roles and responsibilities for teams are defined in the DRP.

The IS auditor should have knowledge of team responsibilities, which are likely to vary from organization to organization.



99

THE BCP AND DRP

The DRP is a part of the BCP.

It outlines the restoration plan that will be used to return operations to a normal state.

In general, a single integrated plan is recommended to ensure that:

- Coordination between various plan components supports response and recovery.
- Resources are used in the most effective way.
- Reasonable confidence can be maintained that the enterprise will survive a disruption.

ISACA

100

IT BCP

IT service continuity is often critical to the organization, and developing and testing an information system BCP/DRP is a major component of enterprise-wide continuity planning.

Points of vulnerability are identified and considered during the risk assessment process.

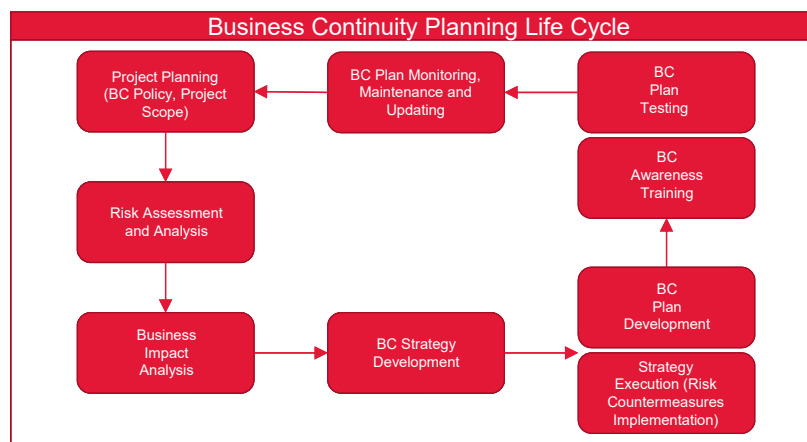
The potential for harm from these can be quantified through a BIA.

ISACA

101

BCP PROCESS

The BCP process can be divided into life cycle phases, as shown here.



ISACA

102

DISASTERS AND DISRUPTIONS

Disasters are likely to require recovery efforts to restore the operational status of information resources.

Categories of disasters include:

- Natural calamities
- Pandemics, epidemics or other infectious outbreaks
- Utility disruptions
- Actions by humans, whether intentionally harmful or through error
- Hardware or software malfunctions
- Incidents causing damage to image, reputation or brand

Some events are unforeseeable. These are referred to as “black swan” events.

ISACA

103

BUSINESS CONTINUITY POLICY

A business continuity policy should be proactive, delivering the message that all possible controls to both detect and prevent disruptions should be used.

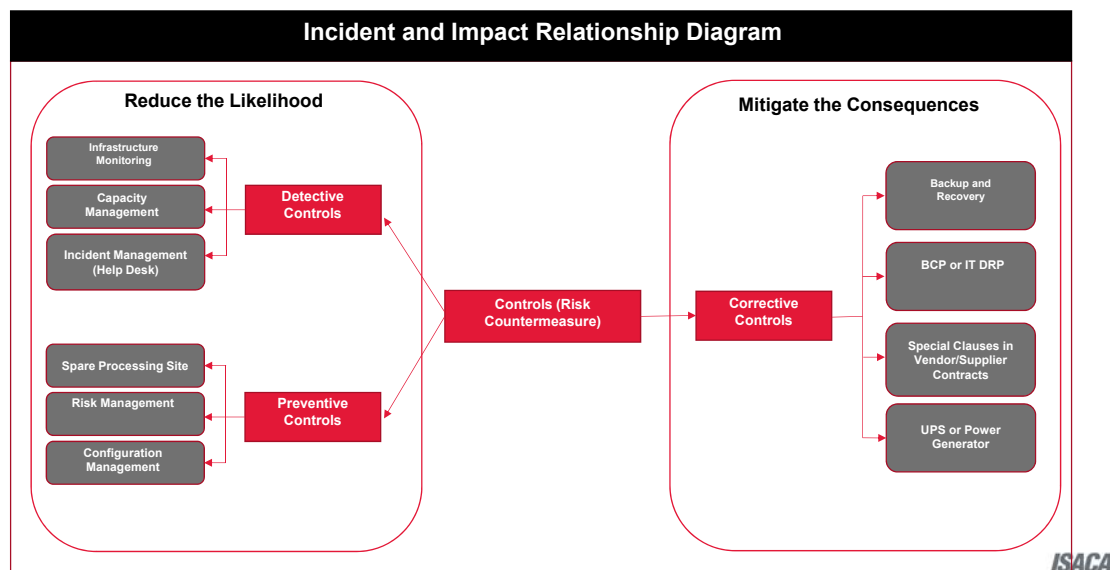
The policy is a document approved by top management; it serves several purposes:

- It carries a message to internal stakeholders that the organization is committed to business continuity.
- As a statement to the organization, it empowers those who are responsible for business continuity.
- It communicates to external stakeholders that obligations, such as service delivery and compliance, are being taken seriously.

ISACA

104

INCIDENT MITIGATION



105

BCP INCIDENT MANAGEMENT

By their nature, incidents and crises often unfold dynamically and rapidly in unforeseeable directions.

Management of such situations requires a proactive approach and supporting documentation.

All incidents should be classified at one of the following levels:

- Negligible — causing no perceptible damage
- Minor — producing no negative financial or material impact
- Major — causing a negative material impact on business processes; possible effects on other systems, departments or outside stakeholders
- Crisis — resulting in serious material impact on the continued functioning of the enterprise and its stakeholders

Note that the classification of an incident can change as events proceed.

ISACA

106

BCP PLAN COMPONENTS



ISACA

107

PLAN TESTING

The critical components of a BCP should be tested under simulated conditions to accomplish objectives such as these:

- Verify the accuracy of the BCP.
- Evaluate the performance of involved personnel.
- Evaluate coordination among response team members and external parties.
- Measure the ability and capacity of any backup site to perform as expected.

Assessing the results and value of the BCP tests is an important responsibility for the IS auditor.

ISACA

108

AUDITING BUSINESS CONTINUITY

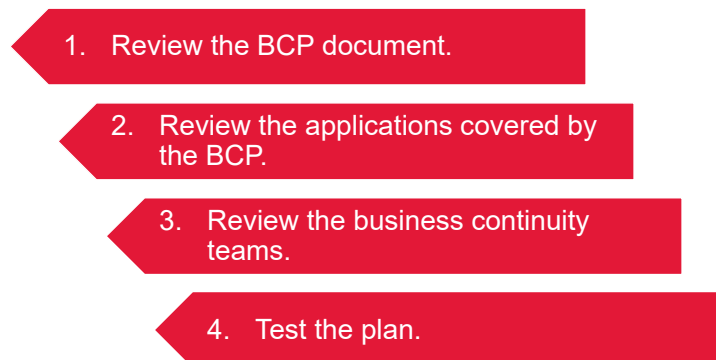
When auditing business continuity, the IS auditor must complete a number of tasks, for example:

- Understanding the connections between BCP and business objectives
- Evaluating the BCP and determining its adequacy and currency
- Verifying BCP effectiveness through a review of plan testing
- Evaluating cloud-based mechanisms and offsite storage
- Assessing the ability of personnel to respond effectively in the event of an incident

ISACA

109

BCP AUDIT REVIEW

*ISACA*

110

BCP AUDIT EVALUATION

Evaluate prior
test results

Evaluate offsite
storage facilities,
including
security controls

Evaluate key
personnel
through
interviews

Evaluate the
alternative
processing
contract

Evaluate
insurance
coverage

ISACA

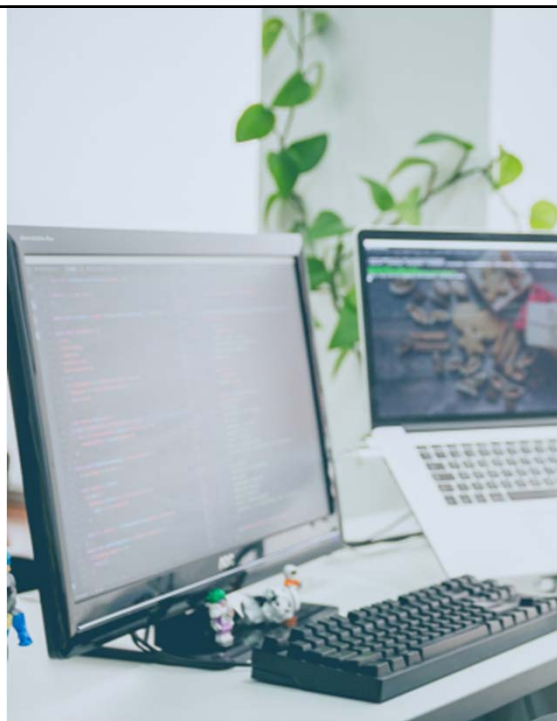
111



ACTIVITY

In preparation for hurricane season, ABC Corporation is having the IS auditor evaluate the existing DRP/BCP to ensure there is reasonable assurance these plans address the required methods and processes that can return the company to normal operations.

What is the most important element in the DRP/BCP the IS auditor should verify is addressed?

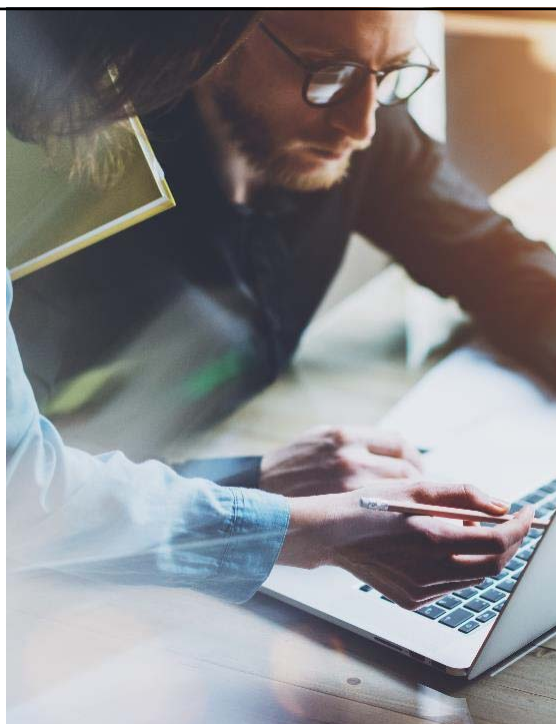


112

DISCUSSION QUESTION

During a review of a business continuity plan, an IS auditor noticed that the point at which a situation is declared to be a crisis has not been defined. The **MAJOR** risk associated with this is that:

- A. assessment of the situation may be delayed.
- B. execution of the disaster recovery plan could be impacted.
- C. notification of the teams might not occur.
- D. potential crisis recognition might be delayed.



113

DISASTER RECOVERY PLANS



114

DISASTER RECOVERY PLANNING

Planning for disasters is an important part of the risk management and BCP processes.

The purpose of this continuous planning process is to ensure that cost-effective controls are in place to prevent possible IT disruptions and to recover the IT capacity of the organization in the event of a disruption.



115

DRP COMPLIANCE REQUIREMENTS

DRP may be subject to compliance requirements depending on:

- Geographic location
- Nature of the business
- The legal and regulatory framework

Most compliance requirements focus on ensuring continuity of service with human safety as the most essential objective.

Organizations may engage third parties to perform DRP-related activities on their behalf; these third parties are also subject to compliance.

ISACA

116

DISASTER RECOVERY TESTING

The IS auditor should ensure that all plans are regularly tested and be aware of the testing schedule and tests to be conducted for all critical functions.

Test documentation should be reviewed by the IS auditor to confirm that tests are fully documented with pre-test, test and post-test reports.

- It is also important that information security is validated to ensure that it is not compromised during testing.

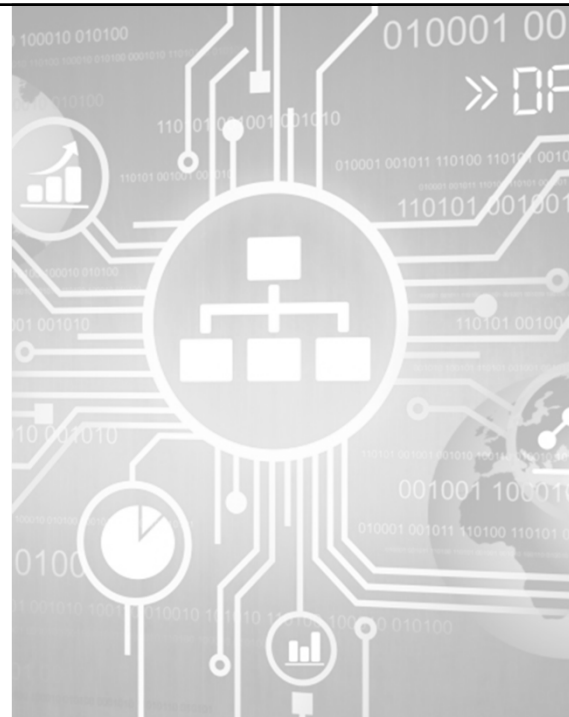
ISACA

117

DISCUSSION QUESTION

When an organization's disaster recovery plan (DRP) has a reciprocal agreement, which of the following risk treatment approaches is being applied?

- Transfer
- Mitigation
- Avoidance
- Acceptance



118

RPO AND RTO DEFINED

Recovery point objective (RPO)

- Determined based on the acceptable data loss in case of a disruption of operations. It indicates the earliest point in time that is acceptable to recover the data.
- The RPO effectively quantifies the permissible amount of data loss in case of interruption.

Recovery time objective (RTO)

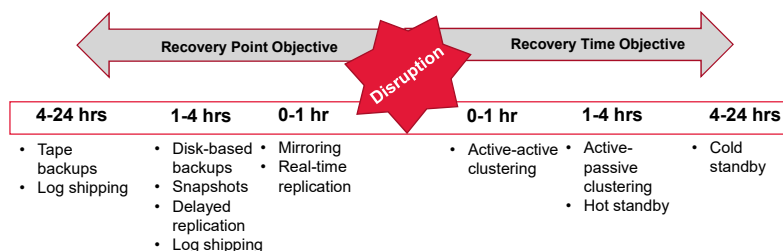
- The amount of time allowed for the recovery of a business function or resource after a disaster occurs.

ISACA

119

RPO AND RTO RESPONSES

Both RPO and RTO are based on time parameters. The nearer the time requirements are to the center, the more costly the recovery strategy. Note the strategies employed at each **time mark in the graphic below.**



ISACA

120

ADDITIONAL PARAMETERS

The following parameters are also important in defining recovery strategies:

- **Interruption window**—The maximum period of time an organization can wait from point of failure to critical services restoration, after which progressive losses from the interruption cannot be afforded.
- **Service delivery objective (SDO)**—Directly related to business needs, this defines the level of services that must be reached during the alternate processing period.
- **Maximum tolerable outages**—The amount of time the organization can support processing in the alternate mode, after which new problems can arise from lower than usual SDO, and the accumulation of information pending update becomes unmanageable.

ISACA

121

RECOVERY STRATEGIES

Documented recovery procedures ensure a return to normal system operations in the event of an interruption.

These are based on recovery strategies, which should be:

- Recommended to and selected by senior management
- Used to further develop the business continuity plan (BCP)



122

RECOVERY STRATEGIES (CONT'D)

The selection of a recovery strategy depends on the criticality of the business process and its associated applications, cost, security and time to recover.

In general, each IT platform running an application that supports a critical business function will need a recovery strategy.

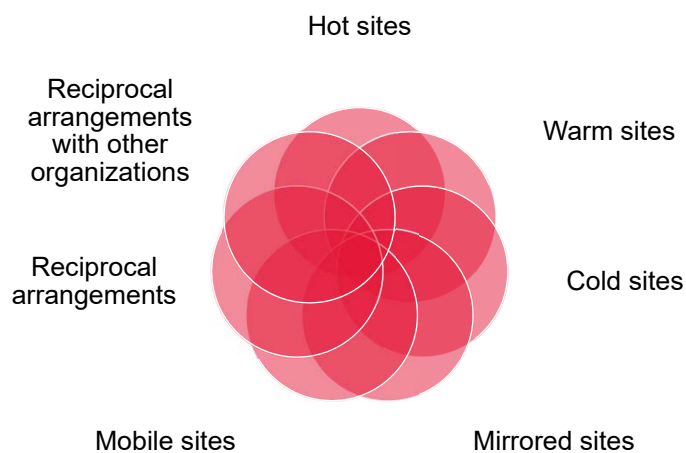
Appropriate strategies are those in which the cost of recovery within a specific time frame is balanced by the impact and likelihood of an occurrence.

The cost of recovery includes both the fixed costs of providing redundant or alternate resources and the variable costs of putting these into use should a disruption occur.

ISACA

123

RECOVERY ALTERNATIVES



ISACA

124

APPLICATION RESILIENCY

The ability to protect an application against a disaster depends on providing a way to restore it as quickly as possible.

A cluster is a type of software installed on every server in which an application runs. It includes management software that permits control of and tuning of the cluster behavior.

Clustering protects against single points of failure in which the loss of a resource would result in the loss of service or production.

There are two major types of application clusters, active-passive and active-active.

ISACA

125

DATA STORAGE RESILIENCY

The data protection method known as RAID, or Redundant Array of Independent (or Inexpensive) Disks, is the most common and basic method used to protect data against loss at a single point of failure.

Such storage arrays provide data replication features, ensuring that the data saved to a disk on one site appears on the other site.



126

DATA REPLICATION

Synchronous

- Local disk write is confirmed upon data replication at other site.

Asynchronous

- Data are replicated on a scheduled basis.

Adaptive

- Switching between synchronous and asynchronous depending on network load.

ISACA

127

TELECOMMUNICATIONS RESILIENCY

The DRP should also contain the organization's telecommunication networks.

These are susceptible to the same interruptions as data centers and several other issues, for example:

- Central switching office disasters
- Cable cuts
- Security breaches

To provide for the maintenance of critical business processes, telecommunications capabilities must be identified for various thresholds of outage.

ISACA

128

NETWORK PROTECTION

Redundancy

Alternative
routing

Diverse
routing

Long-haul
network
diversity

Last-mile
circuit
protection

Voice
recovery

ISACA

129

ACTIVITY

Following the recent flooding events in surrounding states, ABC Corporation has requested an audit of its BCP/DRP plans and processes.

What two elements should the DRP identify and seek to match up in the event of an incident or disaster?



130

DISCUSSION QUESTION

During an IS audit of the disaster recovery plan (DRP) of a global enterprise, the IS auditor observes that some remote offices have very limited local IT resources. Which of the following observations would be the **MOST** critical for the IS auditor?

- A. A test has not been made to ensure that local resources could maintain security and service standards when recovering from a disaster or incident.
- B. The corporate business continuity plan (BCP) does not accurately document the systems that exist at remote offices.
- C. Corporate security measures have not been incorporated into the test plan.
- D. A test has not been made to ensure that tape backups from the remote offices are usable.



131

PRACTICE QUESTIONS

ISACA

132

 PRACTICE QUESTION

Which of the following is the **BEST** indicator of the effectiveness of backup and restore procedures while restoring data after a disaster?

- A. Members of the recovery team were available.
- B. Recovery time objectives (RTOs) were met.
- C. Inventory of backup tapes was properly maintained.
- D. Backup tapes were completely restored at an alternate site.



133

 PRACTICE QUESTION

An IS auditor is reviewing the most recent disaster recovery plan (DRP) of an organization. Which approval is the **MOST** important when determining the availability of system resources required for the plan?

- A. Executive management
- B. IT management
- C. Board of directors
- D. Steering committee

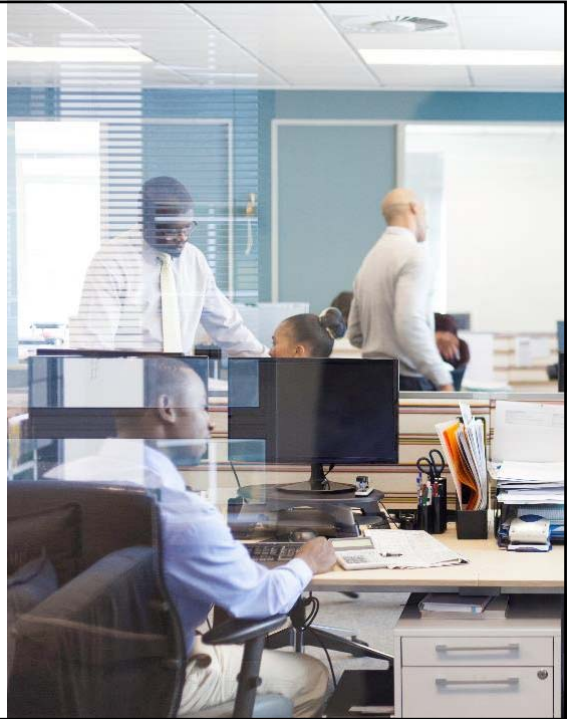


134

PRACTICE QUESTION

Which of the following is the **MOST** efficient way to test the design effectiveness of a change control process?

- A. Test a sample population of change requests
- B. Test a sample of authorized changes
- C. Interview personnel in charge of the change control process
- D. Perform an end-to-end walk-through of the process

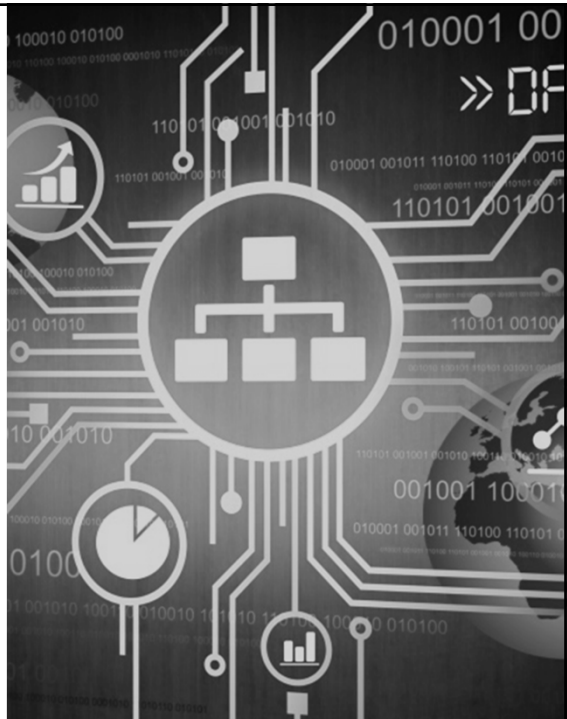


135

PRACTICE QUESTION

Which of the following is the **GREATEST** risk of an organization using reciprocal agreements for disaster recovery between two business units?

- A. The documents contain legal deficiencies.
- B. Both entities are vulnerable to the same incident.
- C. IT systems are not identical.
- D. One party has more frequent disruptions than the other.



136

DOMAIN 4 REVIEW

As an IS auditor, you should now be able to able to:

- Evaluate the organization's ability to continue business operations.
- Evaluate whether IT service management practices align with business requirements.
- Conduct periodic review of information systems and enterprise architecture.
- Evaluate IT operations to determine whether they are controlled effectively and continue to support the organization's objectives.
- Evaluate IT maintenance practices to determine whether they are controlled effectively and continue to support the organization's objectives.
- Evaluate database management practices.
- Evaluate data governance policies and practices.
- Evaluate problem and incident management policies and practices.
- Evaluate change, configuration, release, and patch management policies and practices.
- Evaluate end-user computing to determine whether the processes are effectively controlled.
- Evaluate policies and practices related to asset lifecycle management.

ISACA